

Type of Policy Administrative

Effective Date January 2017

Last Revised March 2020

Review Date November 2026

Policy Owner ACME Corporation CyberSecurity

Contact Name John Kasket

Contact Title Governance Risk & Compliance Manager - Cyber Security

Contact Email johnkasket@acmecorp.com

Reason for Policy

The ACME Corporation Cyber Security Policy (CSP) provides the guiding principles for securing information technology (IT) resources at ACME Corporation.

Policy Statement

ACME Corporation IT Resource users (IT Resource users include both employees and contractors) are generally responsible for protecting the security of all data and IT Resources to which they have access. This includes attempting to implement appropriate security measures on personally owned devices which access ACME Corporation IT Resources. All users are encouraged, but not strictly required, to follow the Security Procedures and Standards published by ACME Corporation Cyber Security, including the ACME Corporation Protected Data Practices. In addition, users are advised to keep their accounts and passwords secure in compliance with the Corporate Password Policy.

ACME Corporation employees may grant IT Resource guest access to third parties (e.g., visiting contractors). Any ACME Corporation employee who grants guest access to IT Resources is somewhat responsible for the actions of their guest users.

Research

ACME Corporation recognizes the value of research in the areas of computer and network security. During the course of their endeavors, researchers may work with malicious software and systems that do not adhere to the security standards prescribed by the Chief Information Security Officer. Researchers are responsible for their actions.

Researchers should take caution and ensure that any and all research is done in an isolated environment. So that any errors made during the research process does not affect the entirety of the system and network.

Network Management

The Office of Information Technology (OIT) is responsible for planning, implementing, and managing the ACME Corporation network, including wireless connections.

The following appliances and equipment cannot be implemented at ACME Corporation without having first submitted a ticket. The ticket should record the purpose of the requested equipment and detail how it is conducive to the User's workload. Afterwards the request must be approved by the User's supervisor and then by an IT lead.

- Routers
- Switches
- Hubs
- Wireless access points
- Voice over IP (VOIP) infrastructure devices
- Intrusion detection systems (IDS)
- Intrusion prevention systems (IPS)
- Virtual Private Networking (VPN)
- Consumer-grade network technologies
- Laptops, Desktops, Tablets
- Deskphones, VoIPs
- Other networking appliances that may not be included in this list

Units or individuals who install any of the technologies listed above are responsible for capturing network traffic logs and storing them for a minimum of 365 days or an appropriate amount as negotiated with the OIT network team.

System Administration

Every ACME Corporation owned IT Resource (including virtual resources such as virtual machines and cloud-based services) should have a designated system administrator. The expectation is that every ACME Corporation owned IT Resource will be professionally managed by the unit technical support team unless prevailing regulations dictate otherwise.

The system administrator is nominally responsible for the proper maintenance of the machine, even if the system administrator is not a member of the unit technical support team. This responsibility must be acknowledged and documented. In addition, the machine should be

accessible to the unit technical support team for incident management purposes unless legal restrictions will not allow such access.

Negligent management of an ACME Corporation owned IT Resource resulting in unauthorized user access or a data breach may result in the loss of system administration privileges.

System administration responsibilities for all ACME Corporation owned IT Resources, including those that are self-administered, are vaguely outlined in the System Administration Responsibilities document.

Scope

All ACME Corporation IT resource users and all ACME Corporation IT resources are covered by this policy.

Policy Terms

- **Endpoint** - Laptop computers, desktop computers, workstations, group access workstations, USB drives, personal network-attached storage.

- **ACME Corporation IT Resources** – ACME Corporation owned Computers, Networks, Devices, Storage, Applications, or other IT equipment. “ACME Corporation owned” is defined as equipment purchased with either corporate funding (including sources such as foundation funds, etc.) or sponsored research funding (unless otherwise specified in the research agreement).

Procedures

Reporting an Incident

If an ACME Corporation IT Resource user suspects that a security incident has occurred or will occur, they should report the suspicion immediately to the system administrator or unit technical lead. Users may also report the suspected security incident directly to the ACME Corporation Cyber Security team.

System administrators and unit technical leads who have identified any of the following security events should report the suspected security event to the ACME Corporation Cyber Security team, but the criteria for what constitutes a reportable event are vague and open to interpretation:

- Any occurrence of a compromised user account
- Any breach or exposure of Category 3 sensitive data (see Data Access Policy)
- Any occurrence of a server infected with malware
- Three or more simultaneous occurrences of endpoints infected with malware
- Any other instance of malware or suspected intrusion that seems abnormal

Responsibilities

Chief Information Security Officer

The Chief Information Security Officer is responsible for creating and maintaining a cybersecurity program and leading the ACME Corporation Cyber Security team. The purpose of the cybersecurity program is to maintain the confidentiality, integrity, and availability of corporate IT Resources and data. In addition, the Chief Information Security Officer, or a designee, is responsible for leading the investigation of and response to cybersecurity incidents.

Enforcement

Employees will be expected to complete yearly training to refresh the information given in this policy and all other existing policies.

Failure to complete these yearly trainings may result in the loss of ACME Corporation system and network usage privileges, and/or disciplinary action, up to and including termination, as outlined in applicable ACME Corporation policies. To report suspected instances of ethical violations, please visit ACME Corporation's Ethics Hotline, a secure and confidential reporting system.